

Homework 1: Due: Sept 16, 2026

Student: Thanh Nam Tran ttran19@umbc.edu

1.1 PART I. TRUE/FALSE QUESTIONS

1. A vulnerability is the deliberate act of exploiting a weakness within a system.

Answer: False. Vulnerability is a flaw or weakness in a system's design not the act.

2. Traffic analysis can give the attacker useful information even if every message on the link is encrypted.

Answer: True.

3. A replay attack is a passive attack since the attacker just resends an intercepted message with no change in its content.

Answer: False. A replay attack is active because the attacker resend a captured message into the system.

4. The idea of open design means that the strength of the cipher depends upon the secrecy of its algorithm, not the secrecy of the key.

Answer: False. It's the opposite. Algorithm is public, key is secret.

5. The increase of the key size of the block cipher from 64 to 128 bits doubles the average effort of the brute-force attack.

Answer: False. The effort is raised by 2^{64} not double.

6. When CBC is used, any single-bit change to ciphertext block C_i corrupts the whole recovered plaintext block P_i , inverts a single bit in P_{i+1} , and leaves all other blocks correct.

Answer: True.

7. To decrypt data in CTR mode, the decryption procedure of the block cipher is needed.

Answer: False. The encryption block is also used in the decryption procedure.

8. AES is a Feistel cipher in which the encryption of only half of the block takes place in each round.

Answer: False. AES is Not a Feistel Cipher.

9. In AES, only the AddRoundKey operation uses the secret key material in a round.

Answer: True.

10. A supply-chain attack that hides a backdoor inside a software library is an attack on the integrity of all applications that use that library.

Answer: True

1.2 PART II. MULTIPLE CHOICE QUESTIONS

Note: The bolded item is the selected answer.

11. A smart doorbell ships with the same default administrator password printed in its publicly available manual. In RFC 4949 terms, the printed default password is a
 - (a) threat
 - (b) **vulnerability**
 - (c) attack
 - (d) countermeasure
12. The attacker cannot decipher the video sent by the home camera, but observes that the rate of uploading increases when someone is at home. What type of attack does the attacker perform?
 - (a) Release of message contents
 - (b) **Traffic analysis**
 - (c) Masquerade
 - (d) Modification of messages
13. Several microservices on one host share a single world-writable temporary directory, so a bug in one service lets it read files written by another. Which design principle is violated?
 - (a) **Least common mechanism**
 - (b) Fail-safe defaults
 - (c) Psychological acceptability
 - (d) Least astonishment
14. A campus door system caches a badge's "access granted" decision for ten minutes, so a badge revoked during that window still opens doors. Which design principle has been violated?
 - (a) Economy of mechanism
 - (b) **Complete mediation**
 - (c) Open design
 - (d) Modularity
15. An attacker obtains an encrypted PDF document and knows that all such documents start with the header %PDF-. What kind of cryptanalytic attack model does the attacker have?
 - (a) **Ciphertext-only**
 - (b) Known-plaintext
 - (c) Chosen-plaintext
 - (d) Chosen-ciphertext
16. Which AES round transformation is omitted from the final round?
 - (a) SubBytes
 - (b) ShiftRows
 - (c) **MixColumns**

- (d) AddRoundKey
17. Which mode of operation requires the plaintext to be padded to a whole number of blocks?
- (a) **CBC**
 - (b) CFB
 - (c) OFB
 - (d) CTR
18. In Asymmetric Encryption, if Alice wants to send a secret message to Bob, she must encrypt the message using:
- (a) Alice's Private Key
 - (b) Alice's Public Key
 - (c) **Bob's Public Key**
 - (d) Bob's Private Key
19. Suppose a large-scale, fault-tolerant quantum computer becomes available. Which of the following statements about its impact on today's cryptography is correct?
- (a) **Shor's algorithm breaks RSA and elliptic-curve cryptography, while AES-256 remains practically secure against Grover's algorithm.**
 - (b) Grover's algorithm breaks RSA and elliptic-curve cryptography, while Shor's algorithm halves the effective key length of AES.
 - (c) Both RSA and AES-256 are completely broken, so all currently deployed cryptography must be replaced.
 - (d) Quantum computers threaten only symmetric ciphers; public-key schemes based on factoring are unaffected.
20. A host needs to send an IP packet to another host on the same local area network but knows only the destination's IP address. Which protocol will help the host obtain the destination's MAC address using its IP address?
- (a) DNS
 - (b) **ARP**
 - (c) BGP
 - (d) TLS

1.3 PART III. SHORT ANSWER PROBLEMS

21. WashPay. In order to turn on a washer, the phone app sends one plaintext message via campus Wi-Fi to the Wi-Fi box attached to the machine. The message consists of the following information: machine ID, campus ID of the student, the amount, and sequence number. The box processes all messages which have a higher sequence number than the previous one and then charges that campus ID later.

- (a) Complete the table: a vulnerability, a threat, and an attack that carries out the threat.

Term	One sentence
Vulnerability	The phone app sends one plaintext message without any protection.
Threat	An attacker on the campus Wi-Fi could intercept a legitimate message and impersonate a student.
Attack	The attacker captures a student's message, creates a forged message with a higher sequence number, and causes charges to be added to that student's account without permission.

(b) Label the attacker on Figure 1, and draw and number the messages of your attack.

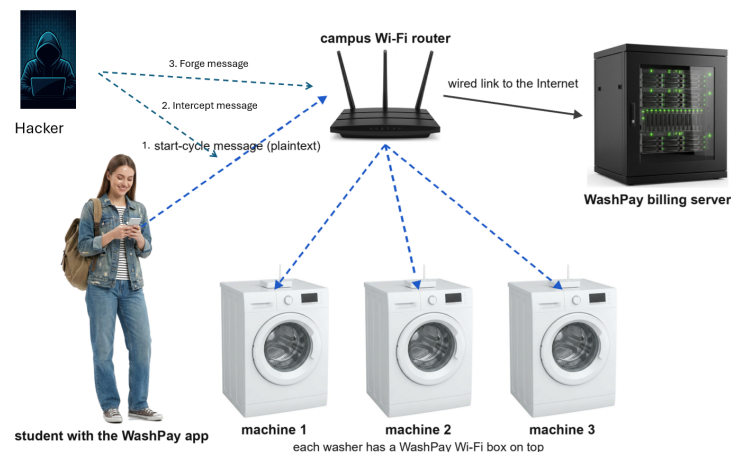


Figure 1.1: Attacker Figure 1 Update.

(c) What security goals does the attack violate, and is it passive or active (which type)? What two design principles does WashPay violate? Give a one-line fix for each.

Answer: Security goals the attack violates Confidentiality and Integrity. The attack performs active attack masquerade on the system.

The two design principles WashPay violate are:

- (a) **Isolation:** The traffic is exposed to other users on the shared campus Wi-Fi. Fix: The traffic network should be protected or the message should be encrypted.
- (b) **Fail-safe defaults:** The system accepts a message based only on its contents and sequence number, without verifying the sender's authorization. Fix: Authenticate every message so that only legitimate student can use the system and be charged accordingly.

22. Inside AES. [15 pts]

- (a) Calculate $\{02\} \cdot 0x9D$, $\{03\} \cdot 0x9D$, $\{02\} \cdot 0x37$, and $\{03\} \cdot 0x37$ in $GF(2^8)$. Write down the shift, any reduction with 0001 1011, and the XORs.

Answer:

Calculate $\{02\} \cdot 0x9D$

Step 1: $9D = 10011101$

Step 2: Shift left 00111010

Step 3: Because the dropped was 1, XOR with 1B. We get 100001

So, $\{02\} \cdot 0x9D = 21$

Calculate $\{03\} \cdot 0x9D = \{02\} \cdot 0x9D \text{ XOR } \{01\} \cdot 0x9D$

Since: $1.9D = 10011101$ and $2.9D = 00100001$

So, $\{03\} \cdot 0x9D = 10111100 = BC$

Calculate $\{02\} \cdot 0x37$

Step 1: $37 = 00110111$

Step 2: Shift left 01101110

Step 3: Because the dropped was 0, no XOR with 1B. So, it's still 01101110 .

So, $\{02\} \cdot 0x37 = 6E$

Calculate $\{03\} \cdot 0x37 = \{02\} \cdot 0x37 \text{ XOR } \{01\} \cdot 0x37$

Step 1: $01101110 \text{ XOR } 00110111$

Step 2: $1011001 = 59$

So, $\{03\} \cdot 0x9D = 59$

- (b) AES-256: number of rounds, number of round keys, and size of expanded key in bytes. What transformation produces confusion, and what transformation propagates changes over a column?

Answer: AES-256 has 14 rounds, 15 round keys, expanded key is 240 bytes. Substitute bytes transformation produces confusion, and Mix Columns transformation propagates changes over a column.

23. Figure 2 is the encryption half of a mode-of-operation diagram from lecture with six items blanked out (A to F). E marks the wire from the first column into the top of the second. [**15 pts**]

- (a) Identify the mode and complete the table. In E, identify the value that flows on the wire and which end of the box it goes into; in F, the width of the bus in bits for AES. [**7 pts**]

Marker	Answer
Mode shown	s-bit Cipher Feedback
A	Initialization vector, IV
B	Shift register
C	Encrypt
D	Select and Discard
E	C_1 go into the right end of the second shift register
F (for AES)	128

- (b) Redraw the first two columns as OFB mode, altering only the connections. [**4 pts**]

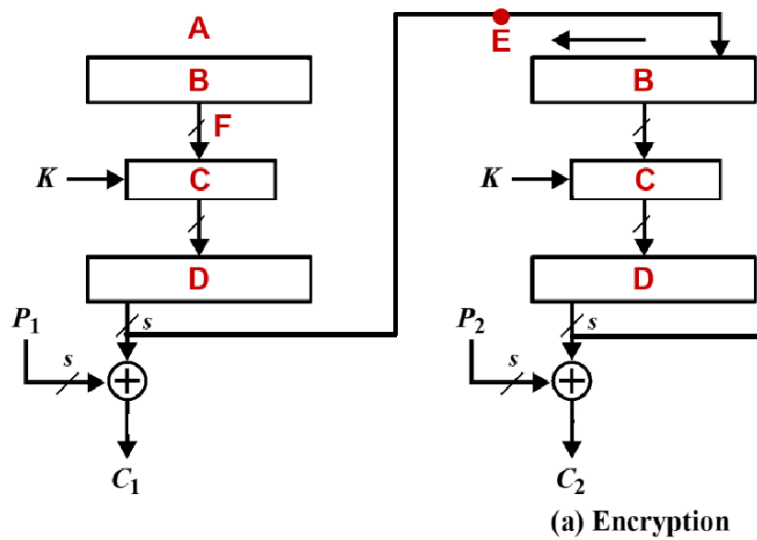


Figure 1.2: OFB

- (c) A single bit in C_1 changes during transmission. Which bits of the plaintext are changed in the mode of Figure 2 and in the OFB version you drew? Which mode is best for a noisy satellite channel? [4 pts]

Answer: Only the corresponding P_i changes in OFB. Therefore, OFB is better for noisy satellite channel since error is not being amplified.

24. Wireshark hands-on. Install Wireshark (free; on Windows the Npcap driver gets installed as well). Start a capture on your active Wi-Fi or Ethernet interface, run the command below in a terminal, access <https://umbc.edu> via the browser, and end the capture. Make sure you capture traffic only from your PC. [15 pts]

```
nslookup xxxx.umbc.edu      (replace xxxx with your UMBC username)
```

- (a) Use the display filter `dns`, find the packet of your DNS request, and take a screenshot of the packet-details pane showing the queried name containing your username, source and destination IPs, and port numbers.

Answer:

- (b) List at least three things a passive attacker on the same Wi-Fi learns from that DNS packet. Which attack type from lecture is this? Which security goal does plaintext DNS fail to provide?

Answer:

3 Things that a passive attacker on the same wi-fi learns from the DNS packet are: the query that contains the student UMBC username, the source port/address, the destination port/address.

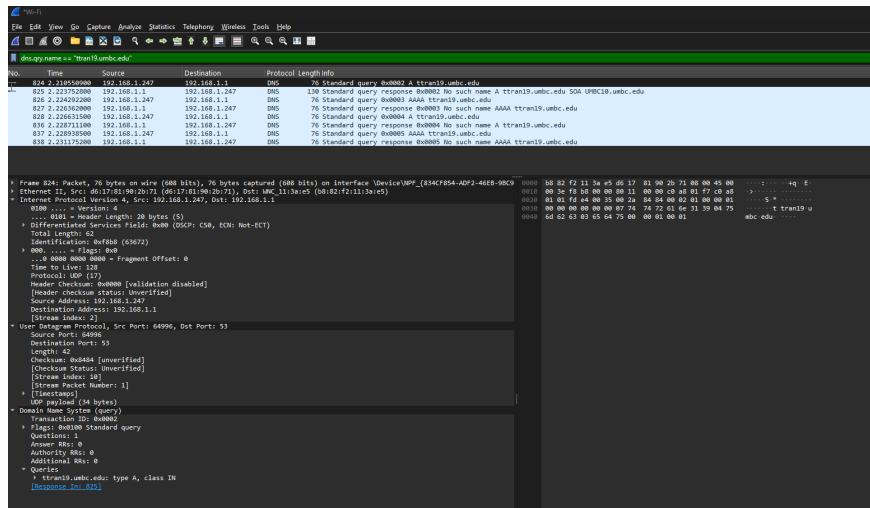


Figure 1.3: Screenshot of the packet-details pane

The attack type is passive eavesdropping where the attacker simply observe the network traffic.

Security goal missing from plaintext DNS is that plaintext DNS fails to provide confidentiality because another person who can observe the traffic can read the requested domain name.

- (c) Filter the traffic with `tls or tcp.port == 443`, take a screenshot of one Application Data packet during the visit of `https://umbc.edu`, and explain what an eavesdropper can and cannot read in it compared with the DNS packet.

Answer: Image is inserted below.

Unlike the plaintext DNS packet, UMBC network traffic is encrypted. While the attacker who is eavesdropping can still see the metadata they cannot read the webpage content.

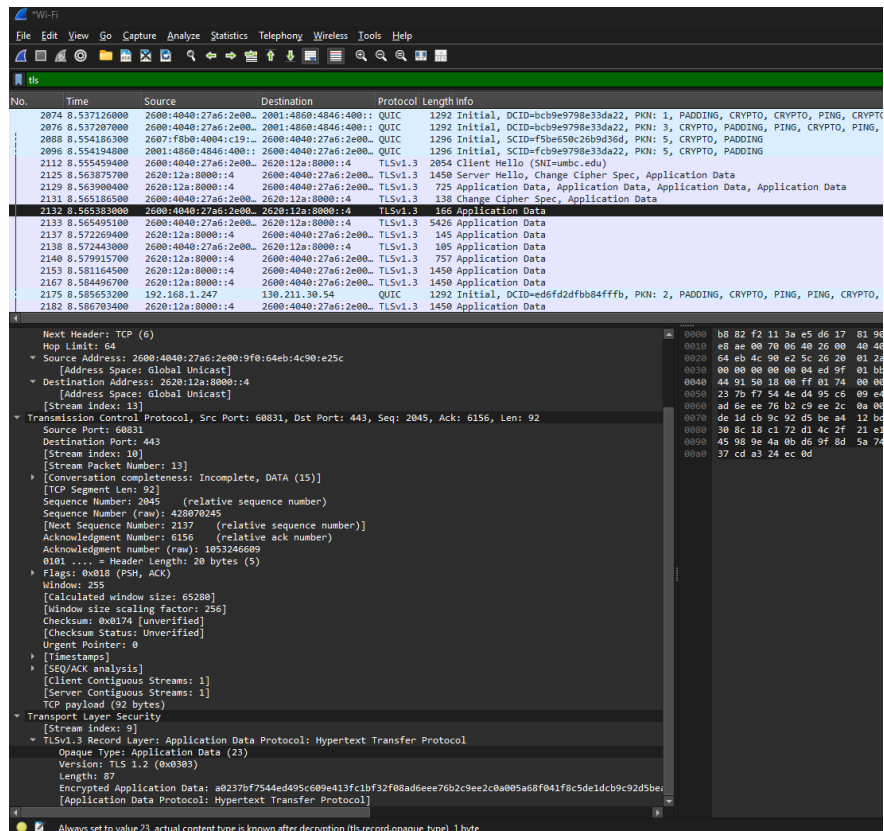


Figure 1.4: Screenshot of the UMBC application data packet